AegisAI Enterprise · Google Cloud Architecture

AI security & compliance auditor · OWASP AISVS v1.0 · ISO/IEC 42001:2023 · EU AI Act · Mexico LFPDPPP / LFPC — as-built deployment + Google Cloud AI Protection Stack

PROJECT computeengine-506321 · REGION us-central1 · CLOUD RUN aegis-ai · FIRESTORE aegis-ai-db · nam5 · MODEL gemini-3.8-flash · global · ACCESS Cloud IAP + Firebase Auth · DOMAINS google.com · fjhuerta.altostrat.com · BASELINE main@c6af106 · Oct 2026

Google Cloud project computeengine-506321 · Argolis · us-central1

Outbound egress allowlist (C04.3) · HTTPS only · IMDS & private ranges blocked

USERS & CLIENTS outside Google Cloud

Administrators & Ops
Admin panel · CLI automation

- /api/admin/* with x-admin-token (SHA-256 timingSafeEqual) or an allowed-domain identity
- Token value read from Secret Manager (aegis-admin-token)

CI/CD pipelines
GitHub Actions · GitLab CI · Jenkins

- POST /api/v1/audits → 202 Accepted + jobId; poll GET /api/v1/audits/:jobId
- AegisAI API key (apiKeys, status active) + Google-signed OIDC token for IAP
- Quality gate: fail the build below the target compliance score

C11.1 quotas · C09.4 saga

Corporate users
Google identities · modern browser

@google.com · @fjhuerta.altostrat.com

AegisAI web app (SPA)
React 19 · Vite 6 · Tailwind CSS 4 · Recharts · jsPDF

- Executive dashboard
- Audit wizard · AISVS / ISO / Full / Custom
- Report viewer + PDF export
- GCP Live Scanner
- Normative catalog
- Architecture & remediation
- API keys for CI/CD
- Admin settings · LLM providers

- Served by Cloud Run (dist/) behind Cloud IAP
- Sends Authorization: Bearer <Firebase ID token>; live audit progress over SSE
- Firebase JS SDK v12: realtime onSnapshot reads & validated writes under Security Rules
- i18n ES / EN · runtime translation PT / FR / DE

EDGE & IDENTITY Zero Trust

Cloud Identity-Aware Proxy
Perimeter sign-in #1 · Cloud Run IAP

ACTIVE

Google Front End · HTTPS
TLS 1.3 · Google-managed certificate

aegis-i-607603788849.us-central1.run.app

- Only domain:google.com and domain:fjhuerta.altostrat.com hold roles/iap.httpsResourceAccessor
- Custom OAuth client (Google Auth Platform · External · In production) for identities outside the org
- IAP service agent is the only roles/run.invoker; legacy user / allUsers grants removed at deploy
- Cloud Run flags: --iap · --no-allow-unauthenticated · --invoker-iam-check
- Forwards the verified identity: x-goog-authenticated-user-email / -id → tenant context
- CI/CD and CLI callers present Google-signed OIDC identity tokens
- Deploy smoke test: anonymous GET /api/health must return 302 / 401 / 403

Zero Trust · C05.3 · C05.4

Firebase Authentication
Identity Platform · in-app sign-in #2

ACTIVE

- Google provider (signInWithPopup) → Firebase ID token (JWT, 1 h, refreshed by the SDK)
- Exact domain allowlist in the SPA (VITE_ALLOWED_DOMAINS) + verified email in Security Rules
- Token sent as Authorization: Bearer to /api/*; server verifies with Admin SDK verifyIdToken → uid, email, tenant domain
- Same identity authorizes direct Firestore access (request.auth in Security Rules)
- Authorized domains (*.run.app hosts) synced at deploy via the Identity Toolkit API
- Demo mode disabled in production (VITE_ENABLE_DEMO_MODE=false)

C05.3 · C05.4

GOOGLE CLOUD RUN service aegis-ai · us-central1 · Node.js 22 · Express 4 · TypeScript (esbuild → dist/server.cjs)

Hardened container
ACTIVE

- node:22-slim multi-stage build · production deps only
- Non-root aegisuser · /app read-only (chmod -R a-w) — C04.1
- Ephemeral /tmp/aegis-runtime-cache; settings persisted in Firestore
- Sandboxed runtime isolation · --dns-result-order=ipv4first

Revision & scaling
- 2 vCPU · 2 GiB · concurrency 40 · timeout 3600 s · port 8080
- min 0 / max 1 instance (in-memory cache backed by Firestore)
- CPU always allocated (async 202 jobs) · startup CPU boost
- Ingress only through IAP · invoker IAM check enforced

Identity & configuration
- Runtime SA aegis-runner-sa · keyless ADC · no API keys (C05.2)
- GOOGLE_GENAI_USE_ENTERPRISE=true · GEMINI_MODEL=gemini-3.8-flash
- GOOGLE_CLOUD_LOCATION=global · FIRESTORE_DATABASE_ID=aegis-ai-db
- ADMIN_API_TOKEN ← Secret Manager aegis-admin-token:latest

4 SECURITY CONTROL PIPELINE — Express middleware & route guards on /api/* (OWASP AISVS)

#	Control	Detail	Tag
1	Security headers	nosniff · SAMEORIGIN · Referrer & Permissions policies	OWASP
2	DNS-rebinding guard	Host & Origin allowlist (*.run.app)	C10.5
3	Anti-probing	dotfiles · .env .key .pem .ts .lock → 404	Hardening
4	Payload limits	JSON 15 MB · uploads ≤ 30 MB · file-type allowlist	Multer
5	Identity context	Firebase ID token · IAP headers · API key · admin token	C05.3 · C05.4
6	Anti-DoW quotas	30 req / 15 min · 3 concurrent · 2.5 M tokens / window	C11.1
7	Injection guard	multi-turn crescendo score · session block ≥ 115	C02.10
8	SSRF egress control	HTTPS only · IMDS & RFC 1918 blocked · allowlist	C04.3

REST API surface
Express routes served by the container

AUDITS	POST /api/evaluate multipart + SSE · POST /api/v1/audits 202 · GET /api/v1/audits/:jobId
FRAMEWORKS	POST /api/frameworks/ingest · GET / DELETE /api/frameworks/:id
GCP SCAN	POST /api/gcp/test-connection · /scan · /audit (SSE)
ADMIN	GET / POST /api/admin/settings · /test-connection · /aims-telemetry
TRUST	GET /api/security/posture · POST /api/mcp/verify
PLATFORM	POST /api/translate-batch · GET /api/health · SPA dist/ · /docs/manuales_pdf

5 Audit evaluation engine
- Evidence extraction: pdf-parse · JSZip · code & Markdown
- Risk level L1 / L2 / L3 + platform shared-responsibility profile
- Chapter batches: AISVS C1–C13 · ISO 42001 Cl. 4–10 & Annex A · EU AI Act · Mexico · custom
- Untrusted input fenced in <user_candidate_architecture> (LLM01)
- Evidence-cited gap map + remediated architecture document

Multi-provider LLM router
- Default gemini → Vertex AI via ADC (keyless)
- 10-model fallback chain · 2 attempts per model · abort timeouts
- Strict JSON responseSchema · temperature 0 · topK 1 · no logprobs (C11.4)
- Optional anthropic · openrouter · openai · custom_openai_compatible
- Every outbound URL validated by the egress allowlist (C04.3)

Governance, trust & telemetry services

Normative integrity	C01.4	Framework ingestion	C09.4
SHA-256 manifest verifies 6 bundled framework snapshots at startup		Legal documents → controls, with compensating saga rollback	
AIMS telemetry	ISO 9.1	Security alerting	C12.2
Citation-grounding rate (SLO ≥ 95 %), determinism, latency, tokens		8 event types → Cloud Logging JSON · security_alerts · SIEM webhook	
MCP manifest checks	C10.1 · C10.2	Posture attestation	Evidence
HMAC-SHA256 signature verification · OAuth2 scope checks		GET /api/security/posture returns live control evidence	

GCP Live Scanner
Read-only posture discovery of audited projects

- Per-scan credentials: OAuth access token · SA key JSON · ADC (off: ENABLE_LIVE_SCANNER_ADC=false) · demo telemetry
- Inventories IAM policy · Cloud Storage · Cloud Run · Vertex AI endpoints & Model Registry (4 regions) · Model Armor templates · Secret Manager
- Flags public endpoints, missing Model Monitoring, models outside Garden / Registry, public buckets, primitive roles, unrotated secrets
- Builds an architecture manifest → evaluation engine (ISO 42001 / AISVS mapping)

AI PLATFORM Vertex AI + Model Armor · global endpoint

ISO/IEC 42001 · PHASE 3 · MODEL SUPPLY CHAIN
Vertex AI Model Garden & Model Registry
- Active: Gemini is consumed as a Google first-party, verified publisher model from Model Garden
- Model Registry: versioned, lineage-tracked private models — no unvetted internet weights or backdoors
- Live Scanner flags models outside Garden / Registry in audited projects

ISO A.6.1.2 · A.7.3 · C01.4 · C13.1

ISO 42001 · PHASE 3 · INLINE
Model Armor
In front of every LLM call

- In → sanitizeUserPrompt
- Out → sanitizeModelResponse
- Prompt-injection & jailbreak detection
- Malicious URL detection
- RAI filters: hate · harassment · sexual · dangerous
- Sensitive Data Protection: PII & secrets

A.6.2.6 · C02.10 · C07.1

Control point — enabled per environment (API on the egress allowlist). In-app C02.10 guard is active today.

Vertex AI · Gemini
ACTIVE

Gemini Enterprise Agent Platform

- Primary gemini-3.8-flash · global endpoint
- Fallbacks 3.7-flash → 3.6-flash → 3.5-flash-lite → 4-argon → 3.1-pro-preview
- Keyless IAM: aegis-runner-sa holds roles/aiplatform.user
- Structured JSON output · deterministic decoding (temp 0, topK 1)
- Enterprise data governance: prompts and outputs are not used for training

C11.4 · C04.3 · Keyless ADC

ISO/IEC 42001 · PHASE 4 · EVALUATION
Vertex AI Evaluation Service · AutoSxS
- AutoSxS autorater compares responses side by side — like a teacher grading homework
- Safety metrics: hate speech · harassment · sexually explicit · dangerous content · immutable evaluation audit trail

ISO Cl. 9.1 · A.6.2.4 · C08.4 · Quality gate before promotion

ISO/IEC 42001 · PHASE 5 · DEPLOYMENT
Vertex AI Model Monitoring
- Training-serving skew & prediction / feature drift detection · immediate alerts when safety degrades
- Live Scanner flags Vertex AI endpoints without monitoring jobs

ISO Cl. 9.1 · A.6.2.6 · C08.4

EXTERNAL SERVICES outside the project boundary

Optional third-party LLM providers
Off by default · provider = gemini (Vertex AI)

PROVIDER	ENDPOINT	DEFAULT MODEL
Anthropic Claude	api.anthropic.com	claude-opus-5-5-max
OpenRouter	openrouter.ai	anthropic/claude-3.7-sonnet
OpenAI	api.openai.com	gpt-4o
OpenAI-compatible · Ollama	custom base URL	llama3.3:latest

- Admin-set keys stay server-side (system_config) and are masked in the UI
- HTTPS only in production; host must be on the egress allowlist (C04.3)
- Per-provider connection test before saving: POST /api/admin/test-connection
- JSON mode (response_format: json_object) · temperature 0 · fallback model · 2 attempts · 180 s timeout

Google Translate (gtx endpoint)
i18n fallback

- translate.googleapis.com — per-string fallback for /api/translate-batch
- Gemini on Vertex AI is the primary translator · in-memory cache

Audited Google Cloud projects
Customer environments · read-only REST

- Resource Manager — project metadata & getIamPolicy: owner / editor grants, allUsers members
- Cloud Storage — uniform bucket-level access, public access prevention, CMEK, versioning
- Cloud Run v2 — default compute SA, all-ingress services, VPC connectors
- Vertex AI — endpoints in 4 regions (public vs. private, Model Monitoring jobs) & Model Registry
- Model Armor — inline templates per region
- Secret Manager — secrets without rotation policies
- Findings mapped to OWASP AISVS, ISO/IEC 42001 and LFPDPPP → audit report
- Scan-to-audit streams progress over SSE (POST /api/gcp/audit)
- Workshop mode: synthetic demo telemetry, no credentials needed

C04.1 · C05.1 · C05.2 · C08.1 · C08.4 · ISO A.6.2.6

AUDIT REQUEST LIFECYCLE

1. **Perimeter sign-in** at Cloud IAP (allowed domains only)
2. **In-app Google sign-in** → Firebase ID token
3. POST /api/evaluate (multipart + SSE) → Cloud Run
4. **Guards:** identity, anti-DoW quotas, injection guard
5. **Engine** extracts evidence, sets L1–L3, batches chapters
6. **Router** → Model Armor control point → Gemini 3.8 Flash
7. Streamed results; report stored in Firestore audits
8. **Dashboard** syncs via Firebase SDK under Security Rules
9. **Security events** → Cloud Logging → SCC / SOC

CI/CD variant: POST /api/v1/audits → 202 + jobId (asyncAudits) → same guards & engine → server saves the report (Admin SDK) → client polls GET /api/v1/audits/:jobId

DATA · CLOUD FIRESTORE aegis-ai-db · Native mode · nam5

COLLECTION	HOLDS	BROWSER ACCESS · SECURITY RULES
audits	Audit reports, gap matrices, remediated architecture	list · get · create · update (schema-validated) · delete ✗ immutable trail · ownerUid immutable
standards_aisvs standards_iso42001	Normative catalog chapters	read · validated create / update · delete ✗
apiKeys	CI/CD API keys (status: active)	read · create · delete by owner / admin · update ✗
asyncAudits	Async CI/CD audit jobs (202 → result)	SERVER ONLY
custom_frameworks	Ingested frameworks + SHA-256 signature	SERVER ONLY
system_config	admin_settings : provider, model, keys	SERVER ONLY · replaces writable /app/config (C04.1)
security_alerts	C12.2 security events	SERVER ONLY · default deny

Security Rules
- isAllowedUser() = signed in ∧ email verified ∧ domain matches @(google[.]com|fjhuerta[.]altostrat[.]com)$
- Default deny on every other path
- Unit-tested (@firebase/rules-unit-testing) & published at deploy

SERVER · ADMIN SDK
- Runs as aegis-runner-sa (roles/datastore.user), bypasses rules for jobs, configs & alerts
- Saga rollback deletes partial audits (C09.4)
- Multi-region nam5 · encrypted at rest & in transit

C05.4 · C09.4

Admin SDK · roles/datastore.user

SECRETS & IDENTITY least privilege

ADMIN_API_TOKEN · secret ref

Secret Manager
ACTIVE

- aegis-admin-token (random 48-hex, created by bootstrap.sh) · secretAccessor only for aegis-runner-sa
- Injected as ADMIN_API_TOKEN (:latest) — never baked into the image or the repo

Cloud IAM · service accounts
ACTIVE

- aegis-runner-sa (runtime) — roles/aiplatform.user · roles/datastore.user · secret accessor (resource-level)
- aegis-build-sa (build) — roles/cloudbuild.builds.builder · roles/logging.logWriter · artifactregistry.writer on the repo
- IAP service agent — sole roles/run.invoker; users get iap.httpsResourceAccessor by domain
- Legacy broad grants pruned (roles/viewer, storage.admin, …)

C05.2

SECURITY OPERATIONS & OBSERVABILITY

Cloud Logging
ACTIVE

- Structured JSON security events (severity, eventType, sccAiProtection)
- Cloud Audit Logs · Cloud Build & request logs

Cloud Monitoring
ACTIVE

- Cloud Run requests, latency, instances, CPU
- Log-based metrics & alerting policies

ISO 42001 · PHASE 5 · DEPLOYMENT
Security Command Center
AI Protection

- AI asset inventory & posture for Vertex AI models, endpoints and Model Armor
- Real-time threat detection: prompt-injection attempts surface as SOC alerts
- Vulnerability findings on endpoints, RAG buckets & IAM
- Event Threat Detection over Cloud Audit Logs

ISO A.6.2.8 · Cl. 10.1 · C12.2

Security Operations Center · SIEM
Outside the project · people & tooling

- Real-time triage of SCC AI Protection findings and CRITICAL / WARNING AegisAI events
- Event types: prompt injection · crescendo escalation · SSRF · DoW quota · admin auth failure · DNS rebinding · integrity failure · saga compensation
- Optional push: SECURITY_ALERT_WEBHOOK_URL (CRITICAL / WARNING)

LEGEND

- User request · HTTPS
- AI inference
- Data persistence (both ways)
- Security events & alerts
- Build & deploy
- Optional egress (allowlisted)
- Model supply / evaluation / improvement
- Deployed component (as-built) · ACTIVE
- AI Protection Stack control · ISO 42001 phase colour (Phase 3 · Phase 4 · Phase 5)
- C04.3 · OWASP AISVS v1.0 control
- A.6.2.6 · ISO/IEC 42001:2023 clause / Annex A
- 1 · Audit request lifecycle step
- Outside the Google Cloud project

publish firestore.rules · deploy new revision

CI/CD & SOFTWARE SUPPLY CHAIN deploy_cloud_run.sh · idempotent · Argolis-ready (scripts/argolis/bootstrap.sh, preflight.sh)

Google Cloud computeengine-506321

01 Developer workstation	02 GitHub repository	03 deploy_cloud_run.sh	04 Cloud Build	05 Artifact Registry	06 Firebase Rules API	07 Cloud Run deploy	08 Access configuration	09 Smoke test
TypeScript · npm run lint (tsc --noEmit) · rules & OWASP test suites · git push	fjhuerta-67/AegisAI · branch main · SSH deploy key · reviewed commits	Pre-checks: Firebase config ↔ project · rules ↔ ALLOWED_DOMAINS · runtime SA & secret exist	cloudbuild.yaml as aegis-build-sa · Docker multi-stage: npm ci → tsc → Vite + esbuild → prod deps	us-central1-docker.pkg.dev/…/cloud-run-source-deploy/aegis-ai:<UTC-tag> · immutable timestamp tags	Publishes firestore.rules to aegis-ai-db (new ruleset + release)	gcloud run deploy · new revision · env vars, secret ref, IAP flags · 100 % traffic	IAP domain bindings · prune legacy invokers · Firebase Auth authorized domains (Identity Toolkit API)	Anonymous GET /api/health must be stopped by IAP (302 / 401 / 403)

QUALITY GATES & ASSURANCE

- Strict type check · tsc --noEmit fails the image build
- Firestore rules tests · @firebase/rules-unit-testing
- OWASP AI security suite · npm run test:security
- Integration verification · npm run test:integration
- LLM provider tests · npm run test:llm
- Live Scanner tests · npm run test:gcp
- SHA-256 normative manifest (C01.4) re-generated on change
- Bilingual manuals & decks (EN / ES) generated from scripts

ISO/IEC 42001 AI LIFECYCLE Google Cloud AI Protection Stack mapped to phases 3 – 5

PHASE 3 · Development & protections
AI system design & development

- **Evidence-based gap map** · ACTIVE — Visual current-vs-target map with L1 / L2 / L3 levels (AegisAI engine)
- **Model Garden / Model Registry** — Signed & verified model supply chain — no backdoored internet models
- **Model Armor** — Inline input / output sanitization · blocks prompt injection & jailbreaks · filters toxic content
- **Remediated architecture** · ACTIVE — Target-state design document with the missing controls, generated per audit

A.6.1.2 · A.7.3 · A.6.2.6 · C01.4 · C13.1 · C02.10 · C07.1

PHASE 4 · Evaluation
Review of applied controls

- **Vertex AI Evaluation Service** — AutoSxS autorater + safety metrics: hate speech, harassment, sexually explicit, dangerous
- **Evaluation audit trail** — Reproducible evidence for certification · quality gate before promotion
- **AIMS telemetry** · ACTIVE — Citation grounding (SLO ≥ 95 %), determinism, latency and token metrics
- **AegisAI control audits** · ACTIVE — Chapter-by-chapter verdicts with verbatim evidence (AISVS, ISO 42001, EU AI Act, Mexico)

Cl. 9.1 · A.6.2.4 · C08.4

PHASE 5 · Deployment
Controlled production deployment

- **Vertex AI Model Monitoring** — Training-serving skew & drift · immediate alerts when safety degrades
- **SCC · AI Protection** — Real-time threat & vulnerability detection · prompt-injection attempts become SOC alerts
- **AegisAI security events** · ACTIVE — 8 event types → Cloud Logging, security_alerts and SIEM webhook
- **Controlled releases** · ACTIVE — Immutable image tags · new Cloud Run revision per deploy · IAP smoke test

Cl. 9.1 · A.6.2.6 · A.6.2.8 · Cl. 10.1 · C08.4 · C12.2

Clause 10 · continual improvement — findings feed back into Phase 3

Derived from server.ts · deploy_cloud_run.sh · cloudbuild.yaml · Dockerfile · firestore.rules · scripts/argolis/* (main @ c6af106). Dashed AI Protection Stack controls are enabled per environment and verified by the Live Scanner.

Icons: Google Cloud official product icons · Lucide (ISC). Generated by scripts/architecture_diagram/generate_architecture_diagram.py